

Table of Contents

Cisco Secure Workload — GDPR Compliance Framework

Reference Design | EU General Data Protection Regulation (2016/679)

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

Legal anchor: Regulation (EU) 2016/679 — this document addresses **technical security evidence** only; **legal interpretation, DPO decisions, legitimate-basis analysis, consent records, and DPIA sign-off** remain with qualified legal counsel and the controller.

Reader's Guide

Who this is for. Data controllers and processors operating in the EU/EEA (or offering goods/services to persons in the Union), including CISOs, privacy engineering teams, DPO *liaisons* (technical), application owners handling personal data, and internal audit.

Important limitation. The GDPR is a **legal and organizational** framework. Cisco Secure Workload (CSW) **does not**:

- determine **lawful basis** for processing;
- manage **consent** banners, cookies, or preference centers;
- fulfill **data subject rights** requests (access, erasure, portability) by itself;
- replace **Records of Processing Activities (RoPA) narratives** — though it can substantiate **data flows** described there with telemetry.

CSW **does** strengthen **Article 32** security of processing and supplies **forensics** that support **Articles 33–34** technical assessment, **Article 25** technical and organizational measures when paired with governance, and **Article 30 / 35 / 28** evidence insofar as your DPIA, RoPA, and processor oversight require **accurate, verifiable** descriptions of how personal data moves and is protected between systems.

Questions this reference design helps you answer:

- *Article 5(1)(f) — integrity and confidentiality: Can we show we implemented appropriate measures to prevent unauthorized processing, loss, or damage, including segmentation and visibility on systems that host or touch personal data?*
- *Article 25 — data protection by design and by default: Can we demonstrate network isolation of personal-data systems and least-privilege connectivity derived from observed need, not assumed trust?*

- *Article 30 — records of processing: Can we corroborate RoPa data flows (which systems exchange personal data, with whom, across which boundaries) using objective telemetry?*
- *Article 32 — security of processing: Can we evidence encryption posture in transit where relevant, segmentation enforcement, vulnerability visibility on workloads processing personal data, and monitoring?*
- *Articles 33–34 — breach notification: If a personal data breach occurs, can we reconstruct timeline, scope of affected systems, and exfiltration/lateral paths to inform supervisory authority and data-subject communication?*
- *Article 35 — DPIA: Can ADM and flow history support our analysis of necessity, proportionality, and residual risks for a new processing operation?*
- *Article 28 — processor / sub-processor oversight: Can we monitor and enforce egress paths from our environment to processors' endpoints and detect deviations?*

What you'll need. GDPR Article 30 inventory (even draft), processing purposes per activity, data categories, **Article 28 / DPAs** listing subprocessors, network diagrams, classification of **systems that process personal data** (including pseudonymised datasets), and legal guidance on **Schrems II / transfer tools** if US cloud regions are in scope.

Where to start. Sections 1–2 for scope; 3–5 to deploy sensors and build personal-data scopes; 6–7 for segregation by design; 8 for control mapping; 9–10 for breach readiness and exports; **Boundaries** before claiming GDPR *compliance* from CSW alone.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by	Primary proof that

CSW term	Meaning	Why compliance teams care
	policy	enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping

- ❑ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ❑ Default-deny posture defined for sensitive scope
- ❑ ADM-imported rules refined; Simulation run ≥ 1 week
- ❑ Change tickets for false-positive fixes; exception register updated
- ❑ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ❑ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ❑ Quarterly pack: inventory, policy, denials, vulns, audit log (see playbook)
- ❑ SIEM integration verified (sample events)
- ❑ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Art. 32 security-of-processing from enforcement + logging
- Art. 30 RoPA support via data-flow mapping
- Art. 33/34 breach timeline from flow search exports

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

The GDPR unifies data protection rules across the EU/EEA and governs the processing of **personal data** and **special categories** where applicable. Controllers must implement **appropriate technical and organizational measures (TOMs)** under **Article 32**, ensure **integrity and confidentiality** under **Article 5(1)(f)**, and embed **data protection by design and by default** under **Article 25**.

CSW contributes to the **technical layer** of those obligations by providing workload inventory, **microsegmentation**, detection of **cleartext or risky protocols**, **application dependency mapping (ADM)**, vulnerability context, **continuous monitoring**, and **forensic flow/process**

data for breach assessment and **DPIA** inputs — always **in conjunction** with encryption products, IAM, DLP, identity governance, contracts, and privacy programme operations.

GDPR articles → CSW capabilities (high level)

GDPR article / theme	Typical compliance questions	Relevant CSW capabilities
Art. 5(1)(f) — Integrity & confidentiality	Are personal data systems protected against unauthorized use, loss, or damage?	Segmentation; flow visibility; cleartext / risky-flow detection; alerts
Art. 25 — Data protection by design & by default	Are we minimizing exposure by default (network & access paths)?	Scopes isolating personal-data tiers; default deny; ADM-driven least privilege
Art. 30 — Records of processing activities	Are documented flows accurate vs reality?	ADM clusters; flow exports cross-checking RoPA
Art. 32 — Security of processing	Confidentiality, integrity, availability, resilience — evidenced how?	Enforcement policies; patch/vuln reports; monitoring; resilience
Art. 33–34 — Breach notification & communication	What happened, when, which systems, extent?	Time-bounded flow + process forensics; scope membership proofs
Art. 35 — DPIA (where required)	What are processing risks & mitigations?	ADM + flow history; policy baseline; before/after for new processing
Art. 28 — Processor & sub-processor terms	Is processing only occurring to documented endpoints?	Egress monitoring; alerts on new external destinations

2. Pre-Deployment Checklist

Before deploying CSW where personal data is processed:

- ☐ **Lawful basis & DPIA status** documented per processing activity (legal owner: DPO / counsel)
- ☐ CSW cluster residency reviewed against **data transfer** decisions (EU-only vs approved SCCs / IDTA, etc.)
- ☐ **DPA** in place with Cisco where CSW processes personal data on behalf of controller (typical SaaS scenario — verify with procurement/legal)

- ❑ **Inventory** of controllers' systems processing personal data — minimum: HRIS, CRM, marketing automation, auth directories, analytics warehouses, backups
 - ❑ Cloud connectors configured for **AWS/Azure/GCP** workloads hosting personal data
 - ❑ Stakeholders: **CISO, DPO/liaison, data owners, processor account managers**
 - ❑ **Data minimization** principles applied to telemetry — confirm whether flow metadata alone suffices for your DPIA (avoid collecting unnecessary payload content in ancillary tools)
-

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 Personal-data processing tiers

Deploy sensors on **every workload** that stores, transforms, or transmits personal data for in-scope activities: application servers, databases, ETL workers, identity services, backup agents on app hosts, microservices in Kubernetes worker nodes (per supported patterns), etc.

Linux

```
sudo rpm -ivh tet-sensor-<version>.rpm      # RHEL family
sudo dpkg -i tet-sensor-<version>.deb        # Debian/Ubuntu
```

```
sudo systemctl enable --now csw-agent
sudo systemctl status csw-agent
```

Windows Server / worker roles processing personal data

```
msiexec /i "\\repo\tet-sensor-<version>.msi" /qn
Get-Service *tet*,*csw* -ErrorAction SilentlyContinue
```

Initial settings:

- **Monitoring Only** until ADM + DPIA-aligned review complete
- Tag early: `gdpr:in-scope, ropa-id:<activity>, data-class:personal`

3.2 Cloud personal-data estates

CSW UI → Platform → External Orchestrators

- Connect cloud accounts processing EU data subjects
- Map tags (cost center, env, `contains-pii`) into scopes
- Enable flow visibility where supported

3.3 Validation

CSW UI → Manage → Agents

- 100% coverage target for in-scope personal-data scopes
 - Escalate uncovered VMs/containers via change process
-

4. Phase 2 — Scope & Inventory Design (Days 6–12)

4.1 Scope hierarchy aligned to processing activities

Tie scopes to **RoPA activity IDs** — not only to network zones.

```
Root: GDPR-In-Scope
├── ROPA-HR-001 / HR-IS                # Employee personal data
├── ROPA-CRM-004 / Customer-360        # Customer personal data
├── ROPA-MKT-006 / Campaign-Automation # Marketing contacts (if
applicable)
├── ROPA-Analytics-009 / Product-Analytics # Pseudonymisation level
documented legally
├── Shared-Services (conditional)
│   ├── IdP-AD                        # personal data attributes? validate legally
│   └── Central-Logging
└── Sub-Processors-Egress
    ├── Payroll-SaaS endpoints (allowlisted FQDNs)
    └── Support-ticketing SaaS
```

4.2 Discovery filters (examples — tune to your estate)

Filter: Personal-Data-DB-Tier

- Process: mysql, postgres, mariadb, sqlservr, mongod
- Tag from CMDB: confidentiality=internal+personenbezogen

Filter: MarTech (if in scope)

- Process contains: hubspot, marketo, salesforce-sync
- Egress domains from RoPA appendix

4.3 Label taxonomy

Label	Values	Purpose
ropa-id	HR-001, CRM-004	Maps evidence to Article 30 record
data-class	personal, special-category, pseudonymised	Legal classification drives technical rigor
processor	payroll-vendor-x	Article 28 monitoring
env	prod, staging	Separate policy workspaces
lawful-basis-ref	internal ticket (not legal advice)	Cross-team traceability only

5. Phase 3 — ADM & Baseline for Personal Data Flows (Days 13–28)

5.1 ADM workspace

CSW UI → Investigate → Application Dependency Mapping
→ Workspace: GDPR-Personal-Data-ADM
→ Scope: GDPR-In-Scope (prod)
→ Window: 3–6 weeks (payroll cycle + monthly batch jobs)
→ Process + user context where available

5.2 ADM ↔ RoPA reconciliation workflow

Step	Owner	Output
1. Export ADM clusters	Security	Cluster list with IPs, processes, ports
2. Map clusters to processing purposes	Data owner + DPO liaison	Updated RoPA appendix
3. Flag undocumented flows to subprocessors	Privacy	Ticket + risk note for DPIA refresh
4. Tag workloads post-validation	IT Ops	Labels ropa-id corrected
5. Re-run ADM after major app changes	Security	Version-controlled export

5.3 Article 25 — by-design segmentation inputs

From ADM, construct **least-privilege** intended connectivity **before** wide enforcement:

- **Default deny** between unrelated RoPA activities sharing a VLAN
 - **Dedicated** scopes for special-category data if legal requires separation
 - **Dedicated** breach-isolation scope for **break-glass** admin
-

6. Phase 4 — Policy Design, Plaintext Detection & Enforcement (Days 22–40)

6.1 Segmentation policies (illustrative)

Replace with your DPIA-approved architecture. **Simulation first.**

DENY: ROPA-MKT-006 → ROPA-HR-001 # marketing / HR separation example
DENY: Any → GDPR-In-Scope (default deny inbound except documented edges)

ALLOW: Customer-360 → IdP-AD (LDAPS 636 / Kerberos – block cleartext LDAP)

ALLOW: HR-IS → Payroll-SaaS-allowlist (443 to enumerated SaaS prefixes only)

LOG + ALERT: Personal-Data-DB-Tier → Internet except documented patch/CDN list

Plaintext / weak-protocol mitigation (Art. 32 technical measure):

- Create **detect-first** rules for HTTP, FTP, LDAP: 389 from scopes labeled `gdpr:in-scope`
- Escalate to **block** after joint sign-off with app owners

6.2 Policy workspace lifecycle

CSW UI → Defend → Segmentation

- Workspace: GDPR-Personal-Data-Prod
- Import ADM rules → legal/DPO review for business flows
- Simulation 2–4+ weeks → phased enforcement

6.3 Enforcement stages

Stage	Objective
Simulation	Measure would-block events; DPIA residual risk update if material
Tier-1 blocks	Stop cleartext admin & obvious internet exposure from DB tier
Full enforcement	Default deny between RoPA scopes except allowlisted conduits

7. Phase 5 — Monitoring, Vulnerability & Resilience (ongoing)

7.1 Monitoring alerts (examples)

Alert	Trigger	GDPR linkage
New subprocessor destination	Flow to IP/FQDN not in RoPA allowlist	Art. 28, Art. 30 accuracy
Cleartext personal-data path	HTTP/LDAP from in-scope DB/app tier	Art. 32, Art. 5(1)(f)
Lateral movement	New east-west path between personal-data scopes	Art. 32, breach assessment
Vulnerability regression	Critical CVE on personal-data workload	Art. 32, risk-based security
Anomalous volume	Possible exfil pattern	Art. 33 technical scoping

7.2 Vulnerability management tie-in

CSW UI → Investigate → Vulnerability Report

- Scope: GDPR-In-Scope
- Export → attach to Art. 32 TOM evidence pack / ISMS control testing

8. Control-by-control mapping — requirement → CSW capability → evidence

GDPR requirement (summary)	CSW capability	Evidence produced
Art. 5(1)(f) — integrity & confidentiality; safeguards against unauthorized processing, loss, destruction, damage	Microsegmentation; monitoring; cleartext/plaintext-path detection; vuln visibility	Policy exports; alert history; flow reports; VA exports
Art. 25(1–2) — data protection by design & by default (appropriate technical measures)	Scopes isolating processing activities; default deny; ADM-driven least privilege	ADM reports; before/after policy versions; architecture memos
Art. 30 — records of processing (accuracy of systems & transfers)	ADM & flow telemetry validating documented flows	RoPA crosswalk spreadsheet + CSW exports
Art. 32(1) — pseudonymisation & encryption (implementation uses complementary tools); ongoing confidentiality, integrity, availability, resilience	Path hygiene (TLS-only); segmentation fault isolation; resilience via anomaly detection	TLS vs plain detection logs; HA architecture tie-in narrative
Art. 32(1)(d) — process for regularly testing effectiveness	Scheduled policy drills; simulation reruns after changes	Test reports; change tickets
Art. 33–34 — personal data breach notice / communication	Flow + process forensics; scope membership proof	Incident timeline bundle; affected-system list skeleton (<i>legal finalizes</i>)
Art. 35 — DPIA where required	ADM + capacity/flow data for necessity & proportionality; residual risk after segmentation	DPIA annex packs (technical appendix)
Art. 28 — processor instructions & safeguards; sub-processors	Egress allowlists; alerts on new destinations; enforcement audit	Processor monitoring dashboards; monthly export to account owner

9. Breach notification readiness (Articles 33–34)

9.1 Technical drill checklist

- ❑ Confirm **UTC time sync** on agents & CSW cluster
- ❑ Run **quarterly** test export: Flow Search restricted to random 1-hour window — validate tooling & analyst skills
- ❑ Maintain **contact tree**: DPO, legal, supervisory authority escalation (*pre-filled by legal*)
- ❑ Map CSW **scope IDs** to **processing activity IDs** for rapid impact narrative

9.2 Evidence bundle contents (non-exhaustive)

CSW UI → Investigate → Flow Search

- Incident start/end
- Affected workload filter (scope or IP list)
- Export: flows with process, user (if present), bytes, duration

CSW UI → Investigate → Process Search

- Suspicious parent/child processes on compromised host

Pair with **IAM logs**, **EDR**, **WAF**, and **application audit** tables — CSW is **one lens** on network/workload truth.

After UI export – package for legal hold (illustrative)

```
mkdir -p ~/gdpr-breach-pack/incident-2026-001/{flows,process,policies}
cp ~/Downloads/flows-*.csv ~/gdpr-breach-pack/incident-2026-001/flows/
shasum -a 256 ~/gdpr-breach-pack/incident-2026-001/flows/* \
> ~/gdpr-breach-pack/incident-2026-001/manifest-sha256.txt
```

10. Audit preparation & evidence export

10.1 Quarterly / annual privacy & security evidence

Evidence item	CSW source	Typical use
Segmentation policy baseline	Defend export	Art. 25, 32 — TOM substantiation
RoPA crosswalk	ADM + spreadsheet	Art. 30 accuracy
Sim-to-enforcement audit trail	Policy workspace history	Change control
Vulnerability report	Vulnerabilities	Art. 32 testing / risk mgmt
Alert summary	Alerts	Art. 32 monitoring effectiveness
Processor egress review	Flow reports filtered by allowlist	Art. 28 oversight

10.2 DPAs & subprocessors

Maintain a **CSW rule object** or **external documentation** listing approved SaaS **FQDNs / IP ranges**. When ADM discovers **new** destinations, route through **vendor risk + legal** before allowlisting.

11. Boundaries — what CSW does **not** cover

- **Lawfulness of processing / consent / legitimate interest balancing** — legal analysis only.
 - **Data subject rights fulfillment** — access, rectification, erasure, portability workflows in business applications and backup rotation.
 - **Privacy notices & transparency** — website / UX content.
 - **International transfer mechanisms** alone — CSW may show *where data flows*; **Schrems II** TIA completion is separate.
 - **Organizational measures**: training, HR sanctions, confidentiality agreements, **pure policy** documents without technical control.
 - **Completeness of RoPA text fields** — purpose, retention schedules, legal basis — CSW cannot author those; it can **validate flows**.
 - **Encryption at rest** — typically database/storage layer; CSW does not replace database TDE / storage CMK governance.
-

12. Common pitfalls

Pitfall	Mitigation
Assuming encryption because HTTPS default port	Validate SNI , termination points, & east-west plaintext
Scoping CSW only to EU region subnets while US teams administer	Include admin paths; document transfers
Stale RoPA after cloud refactor	Re-run ADM on every major architecture change
Over-collecting evidence with personal data inside SIEM	Prefer metadata flows; align with minimization
Treating CSW export as DPIA sign-off	DPIA remains accountable to controller + DPO

Related Frameworks

- [ISO/IEC 27001:2022](#) — common dual-track with GDPR technical measures.
- [NIS2 \(EU 2022/2555\)](#) — for essential entities also under NIS2.
- [SOC 2](#) — when SaaS processors request security attestations alongside GDPR DPAs.
- [NIST SP 800-207](#) — zero trust segmentation patterns underpinning Article 25 narratives.

Appendix A — Example “plaintext detection” policy fragment (conceptual)

```
workspace: GDPR-Personal-Data-Prod
phase: simulation
rules:
  - name: alert-http-from-pii-tier
    action: alert
    src_scope: Personal-Data-App-Tier
    dst_any: true
    services:
      - tcp/80
    notes: "Escalate to block after app owner confirms TLS available."
  - name: block-ldap-cleartext-from-app
    action: deny
    src_scope: Personal-Data-App-Tier
    dst_scope: IdP-AD
    services:
      - tcp/389
```

Appendix B — RoPA crosswalk template (spreadsheet columns)

RoPA Activity ID	Processing purpose (legal text)	System / cluster name	CSW scope ID	ADM cluster ref	Subprocessors (Y/N)	Last ADM export date	Notes
------------------	---------------------------------	-----------------------	--------------	-----------------	---------------------	----------------------	-------

Document prepared for customer data-protection discussions. Legal review required before external assurance or regulatory submission.